

Malware Analysis Report: VBS.LoveLetter (Polish "RACHUNEK" Variant)

Analyst: Darlin Diaz
Date: October 2026
Sample: VBS.LoveLetter ("ILOVEYOU"), sourced from theZoo
Environment: Isolated FLARE-VM + REMnux lab (Proxmox homelab)

Executive Summary

I analyzed a sample of VBS.LoveLetter, the VBScript worm behind the 2000 "ILOVEYOU" outbreak, in an air-gapped lab. Static analysis showed it was not the original worm but a **Polish copycat variant**: the email lure was renamed to "RACHUNEK" (Polish for "bill/invoice"), its self-copies were renamed, and the password-stealing download from the original was removed.

Key findings:

- **The variant expanded its target list.** Unlike the 2000 original, it also targets `.txt` and `.html` files. It hides the victim's original file and leaves a `.vbs` copy of itself beside it.
- **Least privilege defeated its persistence.** Run as a standard user with UAC enabled, every attempt to copy itself into Windows folders and write the HKLM Run key failed with ACCESS DENIED. The worm could not survive a reboot.
- **Failures were invisible to the user.** `On Error Resume Next` suppressed roughly 45 failed write attempts. Nothing appeared on screen; Process Monitor recorded every one.
- **Detection:** I wrote a two-tier YARA rule that matched 6/6 copies of the worm with **0 false positives across 7,272 legitimate scripts**.

1. Lab Environment

Component	Role
FLARE-VM (Windows 10)	Analysis workstation: Procmon, Regshot, Notepad++, YARA
REMnux	Simulated internet (INetSim) answering DNS, HTTP and SMTP
Isolated network	Analysis VMs have no route to the internet or home network

The sample was transferred into the lab on a **read-only virtual CD (ISO)**, so no network path into the isolated segment was ever opened. Isolation was verified before detonation, and the analysis VM was reverted to a clean snapshot afterwards.

2. Sample Identification

Field	Value
File name	VBS.LoveLetter.txt.vbs (9,686 bytes)
SHA256	D3F6956E01E2A4BCDBDCE1B41D0F31E546A102DC384FC9E81B9F1D912E099A13
Type	VBScript worm
VirusTotal	49/61 detections
Vendor names	Worm[email]:Win/LoveLetter.NMS (AliCloud), Generic.ScriptWorm.11A85963 (BitDefender), I-Worm/LoveLetter (Jiangmin)

Variant indicators: the lure name RACHUNK.TXT.vbs and dropped file RACHUNEK.HTM (Polish "bill/invoice"), and self-copies named MSKernel.vbs / WinDLL.vbs instead of the original's MSKernel32.vbs / Win32DLL.vbs.

3. Static Analysis

I read the full source before running anything. The worm's main routine runs in this order:

1. **Self-copy:** copies itself three times into Windows folders under names that imitate system files.
2. **Persistence (regruns):** writes registry autostart entries pointing at its copies, and changes the Internet Explorer start page.
3. **Lure file (html):** creates an HTML file used for spreading.
4. **Email spreading (spreadtoemail):** mails itself to every contact in the Outlook address book, recording each contact in the registry so it does not send twice.
5. **File infection (listativ / infectfiles):** crawls every drive and infects files by extension.

Notable techniques:

- **Double file extension:** the attachment RACHUNK.TXT.vbs displays as RACHUNK.TXT when Windows hides known extensions.
- **Masquerading:** MSKernel.vbs and WinDLL.vbs are named to blend in with real Windows components. WinDLL.vbs is a script, not a DLL.
- **Silent failure:** On Error Resume Next makes every error invisible.
- **Legacy persistence:** a backup entry in the RunServices key, which only Windows 95/98 honors.

Before detonating, I recorded predictions for a standard-user run (Section 5).

4. Dynamic Analysis

Method: Procmon filtered to wscript.exe, Regshot before/after snapshots, and a bait folder (C:\AAA_Bait) containing test.jpg, song.mp3, script.js, notes.txt and page.html. The worm was launched by double-click as a standard user with UAC enabled.

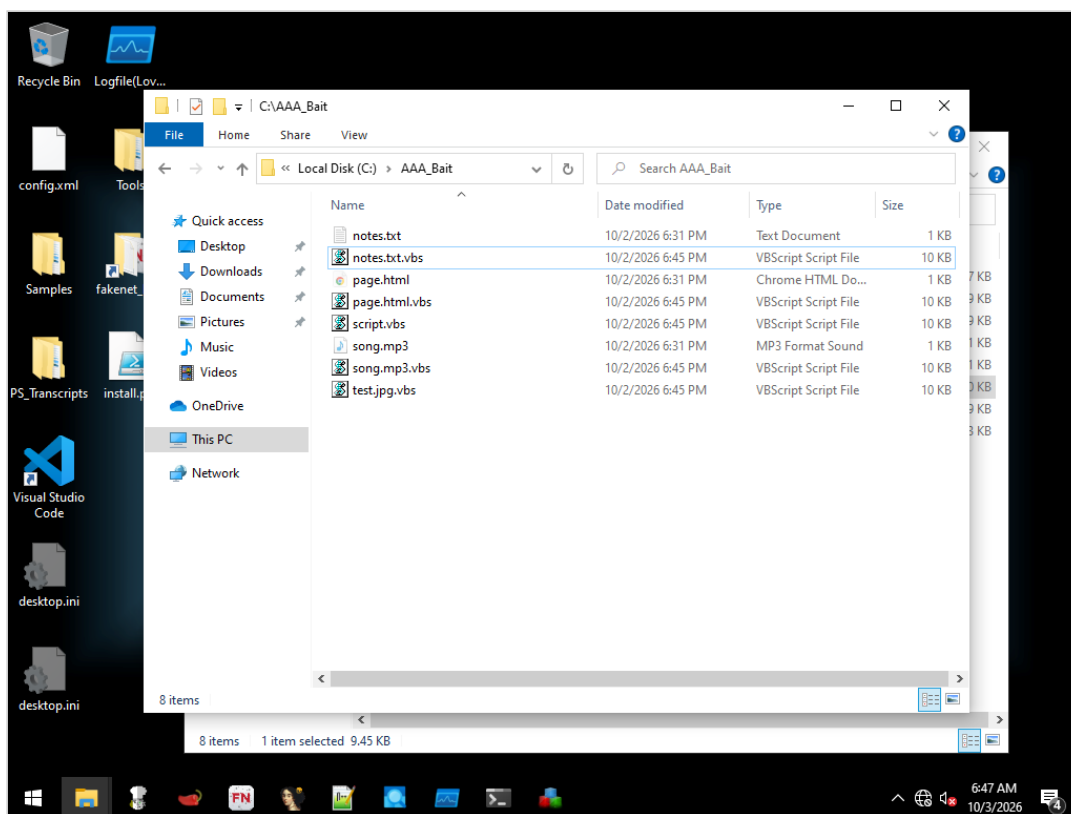
Run 1 (aborted): the worm launched Outlook 2016 (installed on FLARE-VM) and then began crawling the drive alphabetically. Procmon captured over 22 million events and exhausted the VM's memory. I reverted and adjusted the setup: filtered events are now dropped, and the bait folder is named so the crawl reaches it first.

Run 2: the bait folder was infected within seconds. I ended the process after about three minutes, once the evidence was captured.

File infection results

Bait file	Result
script.js	Deleted, replaced by script.vbs (worm code)
test.jpg	Deleted, replaced by test.jpg.vbs
song.mp3	Original hidden , song.mp3.vbs placed beside it
notes.txt	Original hidden , notes.txt.vbs placed beside it
page.html	Original hidden , page.html.vbs placed beside it

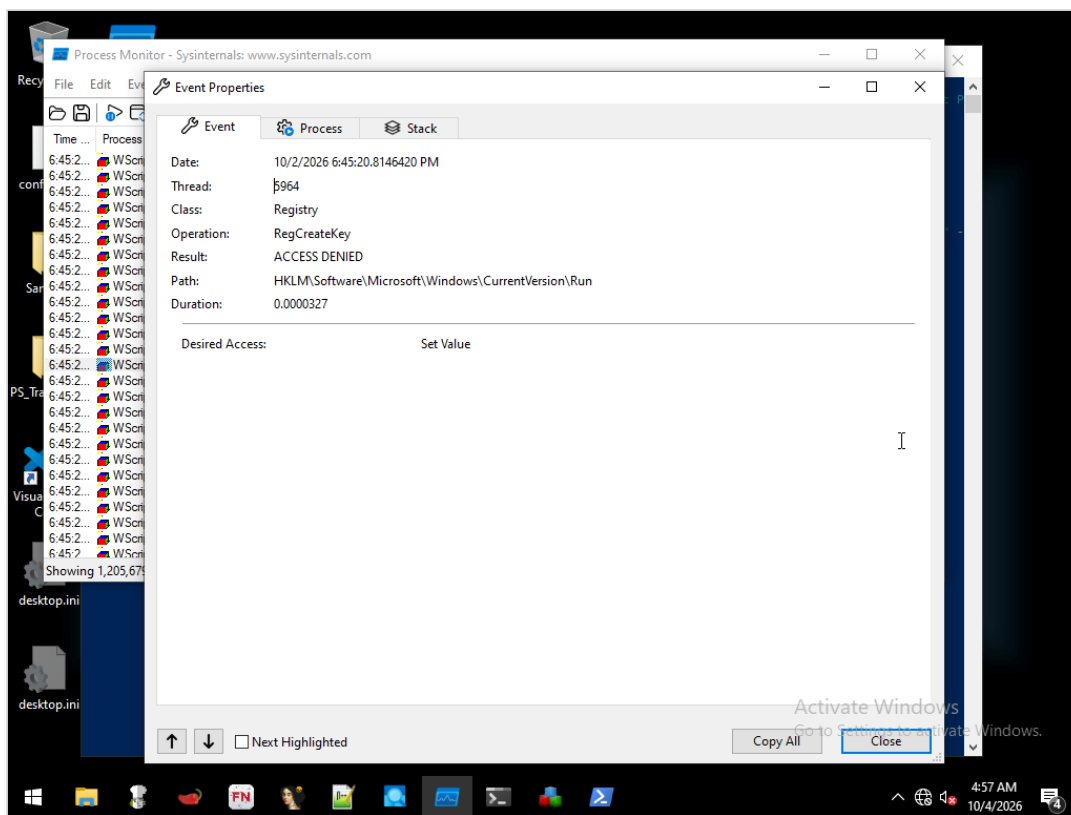
Every .vbs copy has the **same SHA256 as the original sample**. With extensions hidden, a victim sees what looks like their own file, opens it, and runs the worm again.



Persistence attempts (Procmon)

Target	Result
C:\Windows\System32\MSKernel.vbs	ACCESS DENIED (about 15 retries)
C:\Windows\WinDLL.vbs	ACCESS DENIED (about 15 retries)
C:\Windows\System32\RACHUNK.TXT.vbs	ACCESS DENIED
HKLM\Software\Microsoft\Windows\CurrentVersion\Run (Set Value)	ACCESS DENIED
HKCU\Software\Microsoft\Internet Explorer\Main → Start Page	Succeeded: set to <code>www[.]plusgsm[.]pl</code>

With no self-copy and no Run key, **the worm cannot relaunch after a reboot**. Only the per-user (HKCU) browser change succeeded. The start page now points at a legitimate Polish website rather than the original worm's password-stealer download.



5. Predictions vs. Results

Prediction (standard user, UAC on)	Result
Self-copies to Windows folders fail	✓ Correct
HKLM Run key fails	✓ Correct
IE Start Page (HKCU) succeeds	✓ Correct
No visible errors	✓ Correct
.jpg, .mp3, .js bait infected	✓ Correct
.txt and .html bait untouched	✗ Wrong: this variant targets them too

The two missed predictions led to the most significant finding of the analysis: the variant's author expanded the original target list.

6. Indicators of Compromise

Type	Indicator	Confidence
SHA256	D3F6956E01E2A4BCDBDCE1B41D0F31E546A102DC384FC9E81B9F1D912E099A13	High
File	C:\Windows\System32\MSKernel.vbs	High
File	C:\Windows\WinDLL.vbs	High
File	C:\Windows\System32\RACHUNK.TXT.vbs	High
File	C:\Windows\System32\RACHUNEK.HTM	High
File pattern	*.jpg.vbs, *.mp3.vbs, *.txt.vbs, *.html.vbs beside a hidden original	Medium
Registry	HKLM\...\CurrentVersion\Run value MSKernel	High
Registry	HKLM\...\CurrentVersion\RunServices value WinDLL	Medium
Registry	HKCU\...\Internet Explorer\Main Start Page = www[.]plusgsm[.]pl	Medium
Domain	www[.]plusgsm[.]pl, o2[.]pl, playboy[.]com	Low (legitimate sites; context only, do not block)
Email	Attachment RACHUNK.TXT.vbs, displays as RACHUNK.TXT	High

7. MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Phishing: Spearphishing Attachment	T1566.001
Execution	User Execution: Malicious File	T1204.002
Execution	Command and Scripting Interpreter: Visual Basic	T1059.005
Persistence	Registry Run Keys / Startup Folder	T1547.001
Defense Evasion	Masquerading: Double File Extension	T1036.007
Defense Evasion	Masquerading: Match Legitimate Name or Location	T1036.005
Defense Evasion	Hide Artifacts: Hidden Files and Directories	T1564.001
Discovery	File and Directory Discovery	T1083
Discovery	Account Discovery: Email Account	T1087.003
Lateral Movement	Internal Spearphishing	T1534
Impact	Data Destruction	T1485

8. Detection: YARA

Two tiers: a high-confidence **alerting** rule for this variant, and a broad **hunting** rule for the LoveLetter family. String selection avoided generic VBScript constructs (such as `On Error Resume Next`) that appear in legitimate scripts.

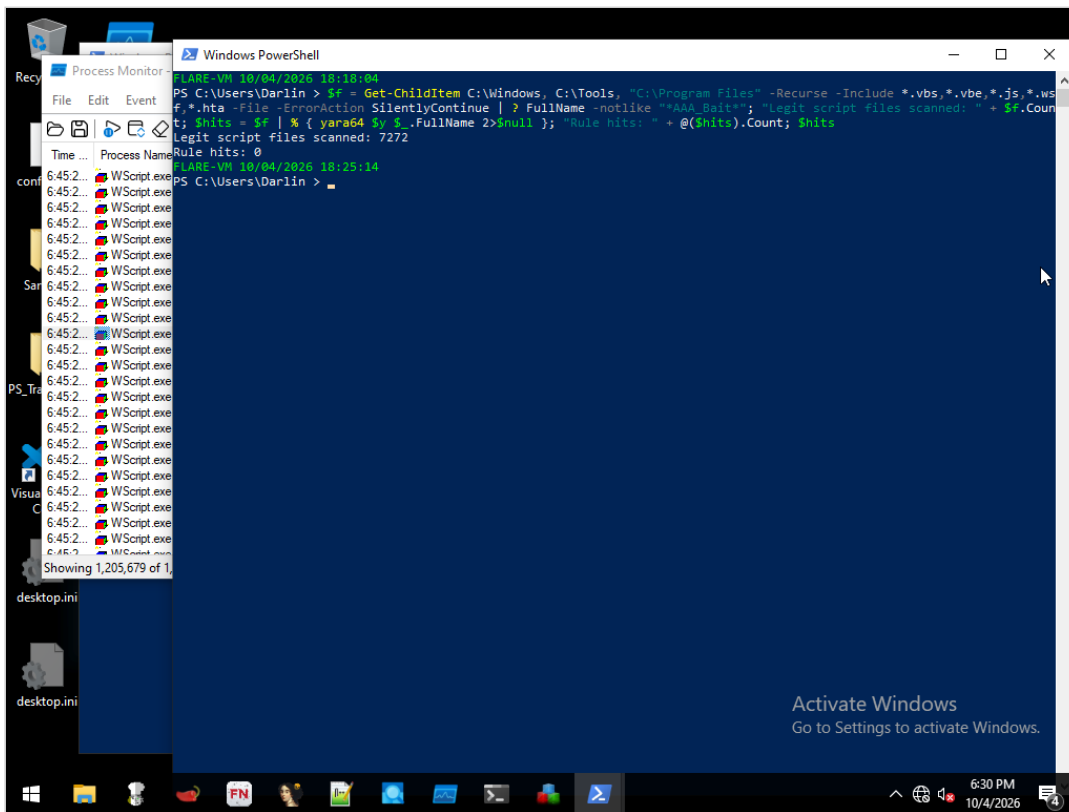
```

rule VBS_LoveLetter_PL_Variant
{
    meta:
        author      = "Darlin Diaz"
        description = "VBS.LoveLetter Polish RACHUNEK variant - alerting rule"
        hash        = "d3f6956e01e2a4bcdbdce1b41d0f31e546a102dc384fc9e81b9f1d912e099a13"
        severity    = "high"
    strings:
        $fam1 = "spreadtoemail"    nocase
        $fam2 = "infectfiles"      nocase
        $var1 = "MSKernel.vbs"     nocase
        $var2 = "WinDLL.vbs"       nocase
        $var3 = "RACHUNK.TXT.vbs"  nocase
        $var4 = "RACHUNEK.HTM"     nocase
    condition:
        1 of ($fam*) and 2 of ($var*)
}

rule VBS_LoveLetter_Family_Hunt
{
    meta:
        author      = "Darlin Diaz"
        description = "LoveLetter-family script - hunting rule, review manually"
        severity    = "low"
    strings:
        $fam1 = "spreadtoemail" nocase
        $fam2 = "infectfiles"   nocase
    condition:
        any of them
}

```

Test	Result
Original sample + 5 infected copies	6/6 matched both rules
Encrypted sample archives, benign bait originals	No match
7,272 legitimate .vbs , .vbe , .js , .wsf , .hta files (Windows, Program Files, FLARE-VM tools)	0 false positives



9. Lessons Learned

- **Least privilege works.** A standard user account with UAC stopped this worm's persistence entirely.
- **Logs over the screen.** The user saw nothing; Procmon showed about 45 blocked writes.
- **Predict first.** Writing predictions before detonation turned two wrong guesses into the key finding.
- **Configure tools before detonating.** Unfiltered Procmon capture crashed the first run, and a Regshot setting left at its default missed the bait folder.
- **Know the analysis environment.** FLARE-VM ships with Outlook, which the worm launched.
- **IOCs need judgment.** Exact paths and value names matter, hashes follow content rather than file names, and legitimate domains should be treated as context, not blocked.